

Vendor Risk Management

Owner: Mark Stolte, Founder — markstolte02@gmail.com

Last reviewed: 2026-07-05

Stage: Pre-launch / active development

Purpose

Lists every third party with access to Penny Pilot's systems or user data, what they can access, and how that relationship is reviewed. Penny Pilot's product is only as trustworthy as this list, since financial data flows through several of these vendors by design.

Vendor inventory

Vendor	Role	Data it can access	Why chosen
Plaid	Bank account linking and transaction sync (supabase/functions/plaid)	Bank login credentials (handled entirely within Plaid Link, never seen by Penny Pilot), account/transaction data it returns to Penny Pilot's backend	Industry-standard bank-data aggregator for consumer fintech apps; publishes its own security/compliance documentation (reviewed as part of vendor selection).
Supabase	Database (Postgres), authentication, Edge Function hosting	Everything in the schema (see Data Classification & Handling); Supabase, as infrastructure operator, has the technical ability to access underlying storage, subject to Supabase's own controls	Managed Postgres + Auth + serverless functions in one platform, with Row Level Security as a first-class feature that maps well to a user-owned-data model.
Apple (Sign in with Apple, App Store, EAS code signing)	Identity provider for sign-in; app distribution	Apple ID identity claims (name/email, per Apple's privacy-relay options); no financial data	Required for iOS distribution and offered as a privacy-forward sign-in option for users.
Google (Google Sign-In, Play Console)	Identity provider for sign-in; app distribution	Google account identity claims (name/email); no financial data	Required for Android distribution and the most common alternative sign-in option.
Expo / EAS	Build and OTA update infrastructure	Source code at build time; no end-user financial data	Chosen as the React Native tooling and build platform for the whole app.

GitHub	Source control	Full source code, including infrastructure-as-code (Supabase migrations, Edge Function code); no end-user data (secrets are git-ignored)	Standard source control; private repository.
npm ecosystem (open-source dependencies)	Libraries the app is built on	Runs as part of the app/build; see Vulnerability Management for how known-vulnerable packages are tracked	Standard for any React Native/Node project; risk is managed via dependency review, not vendor contract.

What's explicitly not a vendor here

Penny Pilot does not use a third-party AI provider for categorization or forecasting in the current implementation — [docs/technical-architecture.md](#) describes AI categorization as a planned backend service, not yet built. If/when that ships, this document must be updated to list the AI provider, what transaction data it receives, and its own data-handling terms, before it goes live.

Review criteria for a new vendor

Before adding a new vendor with access to Confidential or Restricted-tier data (per [Data Classification & Handling](#)):

1. Does the vendor publish a security/compliance posture (SOC 2 report, security whitepaper, or equivalent)?
2. What is the minimum data/scope Penny Pilot needs to grant it, and can access be scoped to that minimum (API keys, OAuth scopes, IAM roles)?
3. Where are its secrets stored, and does that fit the pattern in [Access Control Policy](#) (backend-only, never in the client)?
4. What is Penny Pilot's process if the vendor has an incident? (At minimum: monitor their status page/security advisories; assess exposure using the [Incident Response Plan](#).)

Review cadence

This inventory is reviewed whenever a vendor is added or removed, and at minimum annually alongside the [Risk Assessment Process](#).